

BreachLens

Security Vulnerability Assessment Report

Target: <https://mongo-test.com>

Scan Date: 2026-06-11

Report Generated: 2026-06-11 18:28

Client: Demo User (demo.breachlens@gmail.com)

Confidential — For Authorized Recipients Only

Executive Summary

BreachLens identified **6 vulnerabilities** with a **Critical risk classification**. The identified security weaknesses pose an immediate and severe threat to your organization's data security and regulatory compliance. Estimated potential financial exposure is **■79,009**. Immediate remediation is strongly advised to prevent potential data breach, financial loss, and reputational damage.

Key Metrics

Metric	Value
Total Vulnerabilities	6
Average Risk Score	86.5/100
Total Estimated Financial Loss	■79,009
Total Remediation Cost	■2.0L
Risk Classification	Critical

Severity Overview

Severity	Count	Color Code
Critical	2	■ Red
High	2	■ Orange
Medium	1	■ Yellow
Low	1	■ Green

Vulnerability Details

1. Authentication Weakness [Critical] Risk Score: 100/100

Description: The login system at <https://mongo-test.com/login> lacks rate limiting, account lockout, and multi-factor authentication. Brute force attacks are feasible.

Recommendation: Implement rate limiting, account lockout after failed attempts, and multi-factor authentication. Use strong password policies.

Breach Probability: 97%

Estimated Financial Loss: ■13.3L

Estimated Fix Cost: ■1.1L

2. SQL Injection [Critical] Risk Score: 100/100

Description: SQL injection vulnerability detected in the login form at <https://mongo-test.com/login>. The 'username' parameter is directly concatenated into SQL queries without parameterization.

Recommendation: Use parameterized queries / prepared statements. Implement input validation and use an ORM framework.

Breach Probability: 95%

Estimated Financial Loss: ■48.5L

Estimated Fix Cost: ■70,539

3. Cross-Site Scripting (XSS) [High] Risk Score: 100/100

Description: Reflected XSS vulnerability found in the search functionality at <https://mongo-test.com/search>. User input in the 'q' parameter is rendered without sanitization.

Recommendation: Implement output encoding using Content Security Policy (CSP). Sanitize all user inputs with libraries like DOMPurify.

Breach Probability: 76%

Estimated Financial Loss: ■17.1L

Estimated Fix Cost: ■51,362

4. Insecure Direct Object Reference (IDOR) [High] Risk Score: 100/100

Description: IDOR vulnerability in API endpoint <https://mongo-test.com/api/users>. User IDs are sequential and accessible without proper authorization checks.

Recommendation: Implement proper access control checks. Use UUID-based identifiers and validate user ownership of resources.

Breach Probability: 88%

Estimated Financial Loss: ■20.3L

Estimated Fix Cost: ■52,609

5. Open Directory Listing [Medium] Risk Score: 100/100

Description: Directory listing is enabled on the server at <https://mongo-test.com/backup>, exposing sensitive files including configuration backups and database dumps.

Recommendation: Disable directory listing on the web server. Configure appropriate directory permissions and use index files.

Breach Probability: 54%

Estimated Financial Loss: ■4.1L

Estimated Fix Cost: ■24,491

6. Server Information Disclosure [Low] Risk Score: 18.8/100

Description: Server version information is exposed in HTTP response headers at <https://mongo-test.com>. This aids attackers in targeting known vulnerabilities.

Recommendation: Disable server banner in response headers. Configure web server to hide version details.

Breach Probability: 14%

Estimated Financial Loss: ■79,009

Estimated Fix Cost: ■5,843

Security Recommendations Summary

Immediate Actions (Critical/High)

- Apply patches and security updates for all identified critical vulnerabilities
- Implement parameterized queries to prevent SQL injection attacks
- Deploy Web Application Firewall (WAF) for immediate protection
- Enable multi-factor authentication for all administrative accounts

Short-term Actions (Medium)

- Configure comprehensive security headers (CSP, HSTS, X-Frame-Options)
- Implement proper access controls and authorization checks
- Disable directory listing and sensitive information exposure
- Set up automated vulnerability scanning in CI/CD pipeline

Long-term Actions (Low)

- Establish a bug bounty program for continuous security testing
- Conduct regular security awareness training for development team
- Implement Security Development Lifecycle (SDL) practices
- Schedule periodic third-party penetration testing

This report is generated automatically by BreachLens Security Assessment Platform. The findings are based on automated scanning and should be verified by a qualified security professional. Risk scores and financial estimates are indicative and may vary based on actual exploitation scenarios.